DENY-BY-DEFAULT IN CEDAR

Cedar evaluates each request against all applicable policies and denies it unless a `permit` policy applies and no `forbid` policy overrides it. This deny-by-default approach means you only need to define rules for what is allowed; everything else is implicitly denied. Guardrails, like device security requirements, are best enforced with explicit `forbid` rules, which override any matching `permit`.

9.4 Where does Cedar find data about entities?

The *entity store* is the data source that Cedar queries when evaluating policies. It contains the definitions of principals, resources, and other entities, along with their attributes and relationships. Every test, attribute reference, and relationship traversal in a policy relies on what's stored in the entity store. Since Cedar doesn't specify how the store should be implemented, you can model it in various ways, such as using a directory service, a graph database, relational tables, or even a flat file for development and testing. Selecting the appropriate model for your entity store is crucial for both policy expressiveness and evaluation performance.

The Policy Decision Point (PDP) is responsible for bringing entity data together with policy logic at evaluation time. Essentially, the PDP acts as a wrapper around the Cedar evaluation engine, coordinating the decision process by preparing the necessary inputs—policies, entities, and request context—and then calling Cedar to produce an `allow` or `deny` decision. The PDP does not own the underlying business data, but it manages the decision context, identifing which entities and relationships are needed for a specific request and ensuring they are accessible to the policy engine in a consistent, well-structured format. In some architectures, the PDP fetches this data directly from a relationship graph or directory service; in others, it receives a scoped snapshot of entity data prepared upstream. Regardless of the approach, the PDP sets the boundary between policy evaluation and data access, guaranteeing that every authorization decision is based on a coherent,